

Resumen de la Actividad

Resumen de la Actividad

En esta actividad, crearás un reporte de incidente utilizando el conocimiento que has adquirido sobre redes a lo largo de este curso para analizar un incidente de red. Analizarás la situación utilizando el Marco de Ciberseguridad del Instituto Nacional de Estándares y Tecnología (NIST CSF). El CSF es un marco voluntario que consta de normas, directrices y mejores prácticas para gestionar los riesgos de ciberseguridad. Crear un informe de incidentes de ciberseguridad de calidad y aplicar el CSF puede demostrar un enfoque proactivo de la seguridad, mejorar la comunicación y la transparencia con las partes interesadas y mejorar las prácticas de seguridad dentro de su organización. También puede añadir el informe de incidentes que cree a su cartera de ciberseguridad cuando lo complete.

El CSF es escalable y puede aplicarse en una amplia variedad de contextos. A medida que continúe aprendiendo más y perfeccionando su comprensión de las habilidades clave de ciberseguridad, puede utilizar las plantillas proporcionadas en esta actividad en otras situaciones. Saber identificar qué medidas de seguridad aplicar en respuesta a las necesidades de la empresa le ayudará a determinar cuáles son las mejores opciones disponibles cuando se trata de la seguridad de la red.

Asegúrese de completar esta actividad antes de continuar. En el siguiente punto del curso, podrá autoevaluar su respuesta. Después de eso, habrá un ejemplar completado para comparar con su propio trabajo. También tendrá la oportunidad de responder a las preguntas de la rúbrica que le permitirán reflexionar sobre los elementos clave de su declaración profesional.

Escenario

Revise el siguiente escenario. A continuación, complete las instrucciones paso a paso.

Usted es un analista de ciberseguridad que trabaja para una empresa multimedia que ofrece servicios de diseño web, diseño gráfico y soluciones de marketing en redes sociales a pequeñas empresas. Su organización ha sufrido recientemente un ataque DoS, que comprometió la red interna durante dos horas hasta que se resolvió.

Durante el ataque, los servicios de red de su organización dejaron de responder repentinamente debido a una avalancha de paquetes ICMP entrantes. El tráfico normal de la red interna no pudo acceder a ningún recurso de la red. El equipo de gestión de incidentes respondió bloqueando los paquetes ICMP entrantes, deteniendo todos los servicios de red no críticos fuera de línea y restableciendo los servicios de red críticos.

A continuación, el equipo de ciberseguridad de la empresa investigó el incidente de seguridad. Descubrieron que un actor malicioso había enviado una avalancha de pings ICMP a la red de la empresa a través de un cortafuegos no configurado. Esta vulnerabilidad permitió al atacante malicioso saturar la red de la empresa mediante un ataque de denegación de servicio (DoS).

Para solucionar este problema de seguridad, el equipo de seguridad de la red implementó:

Una nueva regla de cortafuegos para limitar la tasa de paquetes ICMP entrantes

Verificación de la dirección IP de origen en el cortafuegos para comprobar si hay direcciones IP falsificadas en los paquetes ICMP entrantes

Software de supervisión de red para detectar patrones de tráfico anómalos

Un sistema IDS/IPS para filtrar parte del tráfico ICMP basado en características sospechosas

Como analista de ciberseguridad, tiene la tarea de utilizar este evento de seguridad para crear un plan para mejorar la seguridad de la red de su empresa, siguiendo el Marco de Ciberseguridad (CSF) del Instituto Nacional de Estándares y Tecnología (NIST). Utilizarás el CSF para ayudarte a navegar por los diferentes pasos del análisis de este evento de ciberseguridad e integrar tu análisis en una estrategia de seguridad general. Hemos dividido el análisis en diferentes partes en la plantilla que figura a continuación. Puede explorarlas aquí:

Identificar los riesgos de seguridad a través de auditorías periódicas de las redes internas, sistemas, dispositivos y privilegios de acceso para identificar posibles brechas en la seguridad.

Proteger los activos internos mediante la aplicación de políticas, procedimientos, formación y herramientas que ayuden a mitigar las amenazas a la ciberseguridad.

Detectar posibles incidentes de seguridad y mejorar las capacidades de supervisión para aumentar la rapidez y eficacia de las detecciones.

Responder para contener, neutralizar y analizar incidentes de seguridad; implantar mejoras en el proceso de seguridad.

Recuperar el funcionamiento normal de los sistemas afectados y restaurar los datos y/o activos de los sistemas que se hayan visto afectados por un incidente.

Activity Overview

Activity Overview

In this activity, you will create an incident report using the networking knowledge you have gained throughout this course to analyze a network incident. You will analyze the situation using the National Institute of Standards and Technology Cybersecurity Framework (NIST CSF). The CSF is a voluntary framework consisting of standards, guidelines, and best practices for managing cybersecurity risks. Creating a quality cybersecurity incident report and applying the CSF can demonstrate a proactive approach to security, improve communication and transparency with stakeholders, and enhance security practices within your organization. You can also add the incident report you create to your cybersecurity portfolio when you complete it.

The CSF is scalable and can be applied in a wide variety of contexts. As you continue to learn more and refine your understanding of key cybersecurity skills, you can use the templates provided in this activity in other situations. Knowing how to identify which security measures to apply in response to business needs will help you determine the best options available when it comes to network security.

Make sure to complete this activity before continuing. In the next point of the course, you will be able to self-assess your response. After that, there will be a completed example to compare with your own work. You will also have the opportunity to answer rubric questions that will allow you to reflect on key elements of your professional statement.

Scenario

Review the following scenario. Then, complete the step-by-step instructions.

You are a cybersecurity analyst working for a multimedia company that provides web design, graphic design, and social media marketing solutions to small businesses. Your organization has recently suffered a DoS attack, which compromised the internal network for two hours until it was resolved.

During the attack, your organization's network services suddenly stopped responding due to a flood of incoming ICMP packets. Normal internal network traffic could not access any network resources. The incident management team responded by blocking incoming ICMP packets, taking all non-critical network services offline, and restoring critical network services.

Next, the company's cybersecurity team investigated the security incident. They discovered that a malicious actor had sent a flood of ICMP pings to the company's network through a misconfigured firewall. This vulnerability allowed the malicious attacker to saturate the company's network through a denial-of-service (DoS) attack.

To address this security issue, the network security team implemented:

A new firewall rule to limit the rate of incoming ICMP packets

Source IP address verification on the firewall to check for spoofed IP addresses in incoming ICMP packets

Network monitoring software to detect anomalous traffic patterns

An IDS/IPS system to filter some ICMP traffic based on suspicious characteristics

As a cybersecurity analyst, you are tasked with using this security event to create a plan to improve your company's network security, following the National Institute of Standards and Technology (NIST) Cybersecurity Framework (CSF). You will use the CSF to help you navigate the different steps of analyzing this cybersecurity event and integrate your analysis into an overall security strategy. We have broken the analysis down into different parts in the template below. You can explore them here:

Identify security risks through regular audits of internal networks, systems, devices, and access privileges to identify potential gaps in security.

Protect internal assets by applying policies, procedures, training, and tools that help mitigate cybersecurity threats.

Detect potential security incidents and improve monitoring capabilities to increase the speed and effectiveness of detections.

Respond to contain, neutralize, and analyze security incidents; implement improvements in the security process.

Recover normal operation of affected systems and restore data and/or system assets that have been affected by an incident.

Análisis del informe de incidentes



Análisis del informe de incidentes

Instrucciones

A medida que continúe con este curso, puede utilizar esta plantilla para registrar sus hallazgos después de completar una actividad o para tomar notas sobre lo que ha aprendido acerca de una herramienta o concepto específico. También puede utilizar esta tabla como una forma de practicar la aplicación del marco de trabajo NIST a diferentes situaciones que encuentre.

Resumen	Nuestra organización sufrió un ataque de denegación de servicio (DoS) del tipo inundación con mensajes ICMP. El evento comprometió la red interna durante dos horas, provocando que los servicios dejaran de responder repentinamente y que el tráfico normal no pudiera acceder a ningún recurso de la red. El equipo de gestión de incidentes logró mitigar el ataque bloqueando los paquetes ICMP entrantes, desconectando los servicios no críticos y restableciendo los servicios críticos uno a uno.
Identificar	Un actor malicioso dirigió un ataque de inundación ICMP contra la red de la empresa aprovechando una vulnerabilidad en un cortafuegos no configurado. Toda la red interna se vio afectada y el tráfico normal no pudo acceder a ningún recurso. El objetivo prioritario fue identificar los activos afectados para asegurar y restaurar todos los recursos críticos de la red a un estado funcional.
Proteger	Para mitigar la vulnerabilidad y proteger los activos internos, el equipo de ciberseguridad implementó las siguientes medidas concretas:Se aplicó una nueva regla de cortafuegos para limitar la tasa de paquetes ICMP entrantes. Se configuró la verificación de la dirección IP de origen en el cortafuegos para bloquear intentos de suplantación (spoofing) de IP en los paquetes entrantes.

Detectar	Para mejorar las capacidades de detección e identificar rápidamente futuros incidentes, el equipo de seguridad implementó: • Software de supervisión de red destinado a detectar patrones de tráfico anómalos. • Un sistema IDS/IPS configurado específicamente para filtrar tráfico ICMP basándose en firmas y características sospechosas.
Responder	La respuesta inmediata consistió en contener el tráfico malicioso y priorizar los sistemas vitales. Como procedimiento estándar, se debe analizar los registros de red (logs) para evaluar la actividad y reportar el incidente a la alta dirección. Para optimizar futuras respuestas, se propone la creación de un script de automatización que levante los servicios caídos de forma secuencial y automática, priorizando estrictamente desde el servicio más crítico al menos crítico.
Recuperar	La recuperación implicó restaurar el acceso a los servicios de red a un estado de funcionamiento normal sin generar daños colaterales. Dado que el ataque saturó la red e hizo que todos los servicios dejaran de responder, el orden de recuperación ejecutado fue: 1. Bloquear la inundación ICMP externa a nivel de firewall. 2. Mantener detenidos intencionalmente los servicios de red no críticos para aliviar la congestión interna. 3. Restaurar y volver a levantar los servicios de red críticos que habían caído a causa de la saturación. 4. Una vez agotado el tiempo de espera de los paquetes ICMP y normalizado el entorno, volver a poner en línea progresivamente los servicios no críticos.

Reflexiones/Notas: Se podría evaluar la transición hacia un firewall NGFW para automatizar aún más el bloqueo de estos comportamientos

Copia de Análisis del informe de incidentes



Incident report analysis

Instructions

As you proceed with this course, you may use this template to record your findings after completing an activity or to take notes on what you have learned about a specific tool or concept. You can also use this table as a way to practice applying the NIST framework to different situations you encounter.

Summary	Our organization suffered a Denial of Service (DoS) attack of the ICMP flood type. The event compromised the internal network for two hours, causing services to suddenly stop responding and normal traffic to be unable to access any network resources. The incident management team managed to mitigate the attack by blocking incoming ICMP packets, disconnecting non-critical services, and restoring critical services one by one.
Identify	A malicious actor directed an ICMP flood attack against the company's network by exploiting a vulnerability in an unconfigured firewall. The entire internal network was affected, and normal traffic could not access any resources. The priority objective was to identify the affected assets to secure and restore all critical network resources to a functional state.
Protect	To mitigate the vulnerability and protect internal assets, the cybersecurity team implemented the following concrete measures: A new firewall rule was applied to limit the rate of incoming ICMP packets. Source IP address verification was configured on the firewall to block IP spoofing attempts in incoming packets.

Detect	To improve detection capabilities and quickly identify future incidents, the security team implemented: • Network monitoring software aimed at detecting anomalous traffic patterns. • An IDS/IPS system specifically configured to filter ICMP traffic based on suspicious signatures and characteristics.
Respond	The immediate response consisted of containing the malicious traffic and prioritizing vital systems. As a standard procedure, network logs must be analyzed to evaluate activity and report the incident to upper management. To optimize future responses, the creation of an automation script is proposed to restart downed services sequentially and automatically, strictly prioritizing from the most critical service to the least critical.
Recover	Recovery involved restoring access to network services to a normal functioning state without generating collateral damage. Since the attack saturated the network and caused all services to stop responding, the recovery order executed was: 5. Block external ICMP flooding at the firewall level. 6. Intentionally keep non-critical network services stopped to alleviate internal congestion. 7. Restore and bring back up critical network services that had gone down due to saturation. 8. Once the ICMP packet timeout elapsed and the environment normalized, progressively bring non-critical services back online.

Reflections/Notes: The transition to a NGFW firewall could be evaluated to further automate the blocking of these behaviors.